

# Okta user access review

|                |                                                   |
|----------------|---------------------------------------------------|
| Org            | https://acme-demo.okta.com                        |
| Data collected | 2026-09-15 14:00 UTC                              |
| Review date    | 2026-09-15                                        |
| Scope          | 12 users (10 not deprovisioned), 5 groups, 6 apps |
| HR roster      | demo_roster.csv, 9 people, SHA-256 b58126d195fd   |
| Also read      | github:acme-eng (13 principals, read 2026-09-15)  |
| Status         | INCOMPLETE, see data gaps                         |
| Tool           | okta-access-review 0.1.0 (read-only)              |

## Summary

| Severity | CRITICAL | HIGH | MEDIUM | LOW | INFO | Total |
|----------|----------|------|--------|-----|------|-------|
| Findings | 8        | 7    | 8      | 1   | 2    | 26    |

## Data gaps

This review is incomplete. Fix these before relying on it:

- github:acme-eng: omar-haddad has 2 verified emails and no SAML identity, so which person holds this account is not evidenced.
- github:acme-eng: nina-patel has a SAML identity with no attribute this review can join on (every attribute is an opaque identifier, or it states several addresses with no primary), so it cannot be joined to an identity keyed on an email address.
- github:acme-eng: U\_kgDOBq1zzz holds team membership in the acme-eng org but was not returned by the member read. It is counted as unlinked.
- github:acme-eng: sam-departed holds an SSO-authorized credential in the acme-eng org but was not returned by the member read. It is counted as unlinked.

## Findings

| Severity | Check                                                           | Subject                      | Detail                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|----------|-----------------------------------------------------------------|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CRITICAL | AR-01 Terminated in HR but account still live                   | marcus.lee@acme.example      | HR shows terminated on 2026-08-29; Okta status is ACTIVE.                                                                                                                                                                                                                                                                                                                                                                                   |
| CRITICAL | AR-12 Leaver still holds a working credential                   | marcus.lee@acme.example      | Left 2026-08-29 but still holds API token ci-deploy.                                                                                                                                                                                                                                                                                                                                                                                        |
| CRITICAL | AR-13 Activity after the termination date                       | marcus.lee@acme.example      | 2 sign-ins after 2026-08-29; last 2026-09-12 (Salesforce).                                                                                                                                                                                                                                                                                                                                                                                  |
| CRITICAL | AR-17 Someone who left still has access outside Okta            | github:acme-eng/U_kgDOBq1bYx | Left 2026-08-29, but github:acme-eng still shows marcus-lee active holding the organization owner role and personal access token ...5d9e1a4b (last used 2026-08-28 (18 days ago)).                                                                                                                                                                                                                                                          |
| CRITICAL | AR-17 Someone who left still has access outside Okta            | github:acme-eng/U_kgDOBq1cZy | Left 2026-07-15, but github:acme-eng still shows victor-nguyen active holding SSH key (can write; last used 2026-07-14 (63 days ago)), personal access token ...71c3fc9c (can write; last used 2026-09-10 (5 days ago)).                                                                                                                                                                                                                    |
| CRITICAL | AR-17 Someone who left still has access outside Okta            | github:acme-eng/U_kgDOBq1daz | Left 2026-06-30, but github:acme-eng still shows sofia-ramos active holding SSH key (can write; last used 2026-06-28 (79 days ago)).                                                                                                                                                                                                                                                                                                        |
| CRITICAL | AR-18 Service account a leaver owned or held the credentials of | okta/a04                     | Terraform Automation (ACTIVE): Marcus Lee left 2026-08-29, and the strongest evidence of who answers for this okta service account names them -- declared a service account in the review register, owned by marcus.lee@acme.example, Applies infrastructure changes from CI, last reviewed 2026-07-01. It holds the Super Administrator role and Terraform Automation (can write; use not read).                                           |
| CRITICAL | AR-18 Service account a leaver owned or held the credentials of | okta/u12                     | svc-legacy-etl@acme.example (DEPROVISIONED): Marcus Lee left 2026-08-29, and the strongest evidence of who answers for this okta service account names them -- declared a service account in the review register, owned by marcus.lee@acme.example, Nightly CRM extract, last reviewed 2026-07-01. Its okta roles were not read, so whether it holds an elevated role is unknown. Reactivating it restores groups: Sales; apps: Salesforce. |
| HIGH     | AR-02 Contract or end date has passed                           | sofia.ramos@acme.example     | End date 2026-06-30 has passed; Okta status is ACTIVE.                                                                                                                                                                                                                                                                                                                                                                                      |
| HIGH     | AR-03 Account has no HR record                                  | jordan.kim@acme.example      | No HR record for this ACTIVE account.                                                                                                                                                                                                                                                                                                                                                                                                       |
| HIGH     | AR-04 No MFA factor enrolled                                    | lee.chen@acme.example        | Can sign in but has no MFA factor enrolled.                                                                                                                                                                                                                                                                                                                                                                                                 |
| HIGH     | AR-10 API client with admin access                              | Terraform Automation         | API client has admin roles: Super Administrator; write scope: okta.users.manage.                                                                                                                                                                                                                                                                                                                                                            |
| HIGH     | AR-15 Credential nobody is accountable for                      | github:acme-eng/U_kgDOBq1jg5 | dev-contractor-42: no evidence ties this account to a person. Holds fine-grained token 88202 on all repositories (can write; last used 2026-09-13 (2 days ago)).                                                                                                                                                                                                                                                                            |
| HIGH     | AR-16 Access held by an account the source never returned       | github:acme-eng/sam-departed | sam-departed holds credentials: personal access token ...cc70ee11 (can write; last used 2026-08-02 (44 days ago)), but the account was not returned by the github:acme-eng user read.                                                                                                                                                                                                                                                       |
| HIGH     | AR-18 Service account a leaver owned or held the credentials of | okta/a05                     | Reporting Bot (ACTIVE): Victor Nguyen left 2026-07-15, and the strongest evidence of who answers for this okta service account names them -- application.lifecycle.create by victor.nguyen@acme.example on 2026-06-22; and the System Log shows them holding its credentials on 2026-06-22, so a copy may still work. It holds the Read-Only Administrator role and Reporting Bot (last used 2026-09-14 (1 day ago)).                       |

| Severity | Check                                                     | Subject                            | Detail                                                                                                                                                                                              |
|----------|-----------------------------------------------------------|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| MEDIUM   | AR-05 Inactive account                                    | hannah.ortiz@acme.example          | Last sign-in 2026-04-02 (166 days ago).                                                                                                                                                             |
| MEDIUM   | AR-06 Account never used                                  | omar.haddad@acme.example           | Created 2026-07-01, status PROVISIONED, and has never signed in.                                                                                                                                    |
| MEDIUM   | AR-07 Contractor in employee-only group                   | sofia.ramos@acme.example           | Contractor is a member of employee-only group 'Engineering'.                                                                                                                                        |
| MEDIUM   | AR-09 Disabled account still holds access                 | victor.nguyen@acme.example         | Status DEPROVISIONED but still has groups: Finance; apps: Salesforce.                                                                                                                               |
| MEDIUM   | AR-14 App assignment unused                               | lee.chen@acme.example / Salesforce | Assigned directly 2025-06-02; no sign-in since 2026-06-17.                                                                                                                                          |
| MEDIUM   | AR-15 Credential nobody is accountable for                | github:acme-eng/U_kgDOBq1gd2       | omar-haddad: no evidence ties this account to a person. Holds fine-grained token 88203 on subset repositories (write access unknown; no record of use).                                             |
| MEDIUM   | AR-15 Credential nobody is accountable for                | github:acme-eng/U_kgDOBq1kh6       | acme-ci-bot: the review register declares this account and names no owner, so nobody is accountable for it. Holds personal access token ...0af3b210 (can write; last used 2026-09-15 (0 days ago)). |
| MEDIUM   | AR-16 Access held by an account the source never returned | github:acme-eng/U_kgDOBq1zzz       | U_kgDOBq1zzz holds access to Release, but the account was not returned by the github:acme-eng user read.                                                                                            |
| LOW      | AR-08 Missing manager or department                       | grace.park@acme.example            | Profile is missing: manager, department.                                                                                                                                                            |
| INFO     | AR-11 Admin user                                          | jordan.kim@acme.example            | Has admin roles: Help Desk Administrator. Confirm this is still needed.                                                                                                                             |
| INFO     | AR-11 Admin user                                          | priya.shah@acme.example            | Has admin roles: Super Administrator; admin groups: Okta Administrators. Confirm this is still needed.                                                                                              |

## Remediation and control mapping

| Check                                                     | Controls                                                                      | Fix                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-----------------------------------------------------------|-------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AR-01 Terminated in HR but account still live             | SOC 2 CC6.2, SOC 2 CC6.3, ISO 27001 A.5.18                                    | Deactivate the Okta account and confirm app sessions are revoked.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| AR-02 Contract or end date has passed                     | SOC 2 CC6.2, ISO 27001 A.5.18                                                 | Deactivate the account or get the end date extended in HR.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| AR-03 Account has no HR record                            | SOC 2 CC6.2, ISO 27001 A.5.16                                                 | Raise with HR: add them to the roster, list them as a service account, or have the account deactivated. Handled outside the review; no ticket is opened.                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| AR-04 No MFA factor enrolled                              | SOC 2 CC6.1, ISO 27001 A.8.5                                                  | Require MFA enrollment through an authentication policy.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| AR-05 Inactive account                                    | SOC 2 CC6.2, ISO 27001 A.5.18                                                 | Confirm with the manager whether access is still needed; suspend if not.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| AR-06 Account never used                                  | SOC 2 CC6.2, ISO 27001 A.5.16                                                 | Confirm the account is still needed, or deactivate it.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| AR-07 Contractor in employee-only group                   | SOC 2 CC6.3, ISO 27001 A.5.15                                                 | Remove the contractor from the group or document an approved exception.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| AR-08 Missing manager or department                       | SOC 2 CC6.2, ISO 27001 A.5.16                                                 | Fill in the profile so the account has an accountable reviewer.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| AR-09 Disabled account still holds access                 | SOC 2 CC6.2, ISO 27001 A.5.18                                                 | Remove group memberships and app assignments so reactivation doesn't restore access.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| AR-10 API client with admin access                        | SOC 2 CC6.3, ISO 27001 A.8.2                                                  | Confirm each .manage scope and admin role is needed; prefer a least-privilege custom role.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| AR-11 Admin user                                          | SOC 2 CC6.3, ISO 27001 A.8.2                                                  | Reviewer confirms each admin still needs the role.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| AR-12 Leaver still holds a working credential             | SOC 2 CC6.2, SOC 2 CC6.3, ISO 27001 A.5.18                                    | Revoke the API token: deactivating the account does not stop it working. An API client secret they held is AR-18's, because rotating it is confirmed by a reviewer, not by Okta.                                                                                                                                                                                                                                                                                                                                                                                                                              |
| AR-13 Activity after the termination date                 | SOC 2 CC6.2, SOC 2 CC7.2, ISO 27001 A.5.18, ISO 27001 A.8.16                  | Treat as a possible incident: revoke the credential, review what it reached, and confirm the termination date with HR.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| AR-14 App assignment unused                               | SOC 2 CC6.2, ISO 27001 A.5.18                                                 | Remove the direct app assignment in Okta, or record why it is still needed.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| AR-15 Credential nobody is accountable for                | SOC 2 CC6.1, SOC 2 CC6.2, ISO 27001 A.5.16, ISO 27001 A.5.18                  | Establish who owns this account, and revoke its credentials if nobody will own it. Record the owner in the service account register (config.service_accounts): an entry with an owner ties the account to that person, so it appears in their access review and in their departure bundle if they leave. An entry naming no owner declares the account without making anyone accountable, and is still reported here. So is one naming an owner no source evidences as a person -- a misspelled address reads as ownership and reaches nobody, which is why it is worth no more than leaving the field blank. |
| AR-16 Access held by an account the source never returned | SOC 2 CC6.1, SOC 2 CC6.2, SOC 2 CC6.3, ISO 27001 A.5.16, ISO 27001 A.5.18     | Find out what this account is. It reaches things in the org while being absent from the user read, so neither joiner-mover-leaver automation nor this review can see it directly.                                                                                                                                                                                                                                                                                                                                                                                                                             |
| AR-17 Someone who left still has access outside Okta      | SOC 2 CC6.2, SOC 2 CC6.3, ISO 27001 A.5.16, ISO 27001 A.5.18, ISO 27001 A.8.2 | Remove the access and revoke the credentials in that system. Deactivating the Okta account did not reach them, which is why they are still here.                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

| Check                                                           | Controls                                                                                                     | Fix                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AR-18 Service account a leaver owned or held the credentials of | SOC 2 CC6.1, SOC 2 CC6.2, SOC 2 CC6.3, ISO 27001 A.5.16, ISO 27001 A.5.17, ISO 27001 A.5.18, ISO 27001 A.8.2 | Make sure somebody still here answers for this account, and rotate every secret and key the leaver held or could have read; or decommission it: revoke its credentials and remove its access. Deactivating the leaver's own account did not touch this one. The finding says what state the account is in and what it still reaches: a live one is presumably still being called, and a deactivated one restores everything it holds the moment somebody reactivates it. Record the owner in the service account register (config.service_accounts), which ties it to that person's access review and to their departure bundle if they leave in turn. |

## Access by user

Full detail, including apps, is in access\_matrix.csv. Record decisions there.

| Login                       | Status        | Type       | Manager      | Last sign-in | MFA                 | Admin roles             | Groups      |
|-----------------------------|---------------|------------|--------------|--------------|---------------------|-------------------------|-------------|
| grace.park@acme.example     | ACTIVE        | Employee   |              | 2026-09-15   | push, webauthn      |                         | Sales       |
| hannah.ortiz@acme.example   | ACTIVE        | Employee   | CFO          | 2026-04-02   | push                |                         | Finance     |
| jordan.kim@acme.example     | ACTIVE        | Employee   | Grace Park   | 2026-09-12   | push                | Help Desk Administrator | Sales       |
| lee.chen@acme.example       | ACTIVE        | Employee   | Priya Shah   | 2026-09-11   | none                |                         | Engineering |
| marcus.lee@acme.example     | ACTIVE        | Employee   | Priya Shah   | 2026-08-28   | push                |                         | Engineering |
| nina.patel@acme.example     | SUSPENDED     | Employee   | Grace Park   | 2026-05-30   | n/a                 |                         |             |
| omar.haddad@acme.example    | PROVISIONED   | Employee   | Hannah Ortiz | never        | n/a                 |                         | Finance     |
| priya.shah@acme.example     | ACTIVE        | Employee   | CTO          | 2026-09-14   | push, webauthn      | Super Administrator     | Engineering |
| sofia.ramos@acme.example    | ACTIVE        | Contractor | Priya Shah   | 2026-09-10   | sms                 |                         | Engineering |
| svc-ci@acme.example         | ACTIVE        | Service    |              | 2026-09-15   | token:software:totp |                         |             |
| svc-legacy-etl@acme.example | DEPROVISIONED | Service    |              | 2026-06-02   | n/a                 | unknown                 | Sales       |
| victor.nguyen@acme.example  | DEPROVISIONED | Employee   | Hannah Ortiz | 2026-07-14   | n/a                 | unknown                 | Finance     |

## Reviewer sign-off

I reviewed the findings and the access list above and recorded a decision for each user.

Reviewer name

Signature

Date